03.10.2024

# Romsis Yazılım ve Bilgi Teknolojileri

**Inflight Web Uygulama Sızma Testi Raporu v1.1**

Sızma Testi Tarihi:

22.08.2024 - 28.08.2024

RSU
Bilişim ve Danışmanlık

GİZLİ

# İçindekiler

YÖNETİCİ ÖZETİ ..... 2
Test Kapsamı ..... 6
Uyarı ..... 7
Sızma Testi Metodolojisi ..... 8
Web Uygulama Sızma Testi Kontrol Listesi ..... 9
Kullanılan Araçlar ..... 9
WEB UYGULAMA SIZMA TESTİ BULGULARI ..... 10
1. Acil Seviye Web Uygulama Sızma Testi Bulguları ..... 10
2. Kritik Seviye Web Uygulama Sızma Testi Bulguları ..... 10
3. Yüksek Seviye Web Uygulama Sızma Testi Bulguları ..... 10
4. Orta Seviye Web Uygulama Sızma Testi Bulguları ..... 11
4.1. Siteler Arası Betik Çalıştırma (Stored XSS) ..... 11
4.2. Güncel Olmayan JavaScript Kütüphanesi Kullanımı ..... 16
4.3. Parola Politikası Eksikliği ..... 18
4.4. İnternetten Erişilebilir Hassas Servisler ..... 19
5. Düşük Seviye Web Uygulama Sızma Testi Bulguları ..... 20
5.1. HTTP Başlık Bilgisi Eksiklikleri ..... 20
5.2. Hassas Bilgilerin Erişilebilir Olması ..... 22
5.3. Parolaların Veritabanında Açık Şekilde Saklanması ..... 23
5.4. Tilde Kullanarak Dizin Listeleme Bilgisinin Açığa Çıkarılması ..... 24
5.5. Web Sunucu ve Uygulama Versiyon Bilgisinin Açığa Çıkarılması ..... 25

# YÖNETİCİ ÖZETİ

Romsis Yazılım ve Bilgi Teknolojileri Ltd. Şti.'nin (Kurum) risklerinin belirlenebilmesi için, Inflight web uygulamasına anonim ve standart kullanıcı yetkileri ile sızma testleri gerçekleştirilmiştir. Bu testler sonucunda Kurum bilgi varlıklarının güvenliğini etkileyen Acil seviyede bulgu tespit edilmemiştir.

Genel olarak bulgular dikkate alındığında, Kurumun aşağıdaki konularda gelişmeye açık yönleri olduğu değerlendirilmektedir:

- OS/Servis Sıkılaştırması
- Yama Yönetimi
- Girdi Kontrolü
- Uygulama Sıkılaştırması
- Erişim Kısıtlaması
- Kullanıcı Yönetimi

Çalışma sonucunda 4 Orta ve 5 Düşük seviye olmak üzere toplam 9 bulgu tespit edilmiştir. Bulgu dağılımı incelendiğinde, Kurumun güvenlik ürünlerini efektif kullandığı, Kritik zafiyet oluşturabilecek önlemleri genel olarak aldığı ancak güvenli yazılım geliştirme konularında eksiklerinin olduğu görülmektedir. Uygulamada Depolanan XSS, Parola Politikası Eksikliği ve parolaların veritabanında açık şekilde saklanması, güncel olmayan yapıların kullanılması ve İnternetten erişilebilir hassas servislerinin bulunması bu duruma örnek olarak gösterilecek başlıca bulgulardır.

**Tavsiye Özeti:**

Bulguların çoğunluğu OS/Servis ve web uygulama sıkılaştırma kök nedenine sahip olduğu düşünüldüğünde, Kurum bünyesinde güvenli yazılım geliştirme yaşam döngüsünün uygulanması, Kurumun verdiği hizmetlerin akışına göre uygulamaların gözden geçirilmesi bulguların büyük kısmının kapatılmasını sağlayacaktır.

*Web Uygulama Sızma Testi Bulguları*

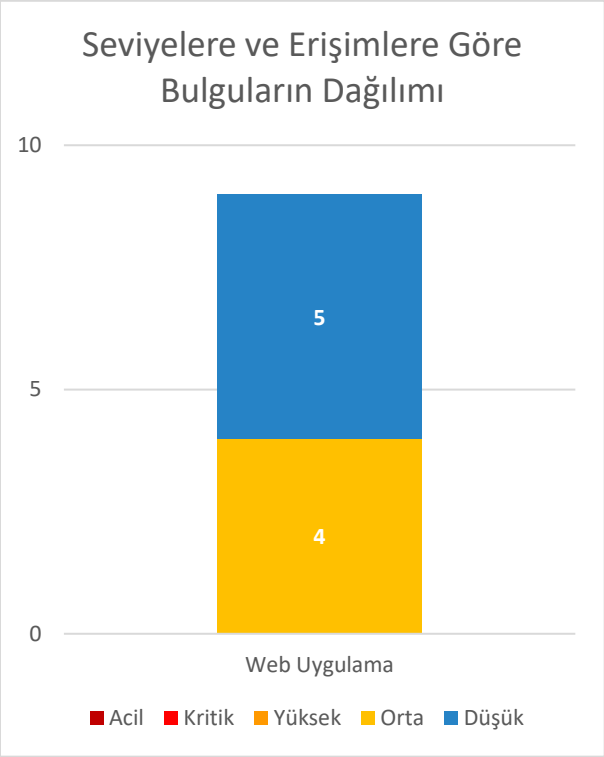
| Seviye | Bulgu Adı | Etkilenen Sistem Sayısı |
|---|---|---|
| ORTA | Siteler Arası Betik Çalıştırma (Stored XSS) | 1 |
| ORTA | Güncel Olmayan JavaScript Kütüphanesi Kullanımı | 1 |
| ORTA | Parola Politikası Eksikliği | 1 |
| ORTA | İnternetten Erişilebilir Hassas Servisler | 1 |
| DÜŞÜK | HTTP Başlık Bilgisi Eksiklikleri | 1 |
| DÜŞÜK | Hassas Bilgilerin Erişilebilir Olması | 1 |
| DÜŞÜK | Parolaların Veritabanında Açık Şekilde Saklanması | 1 |
| DÜŞÜK | Tilde Kullanarak Dizin Listeleme Bilgisinin Açığa Çıkarılması | 1 |
| DÜŞÜK | Web Sunucu ve Uygulama Versiyon Bilgisinin Açığa Çıkarılması | 1 |

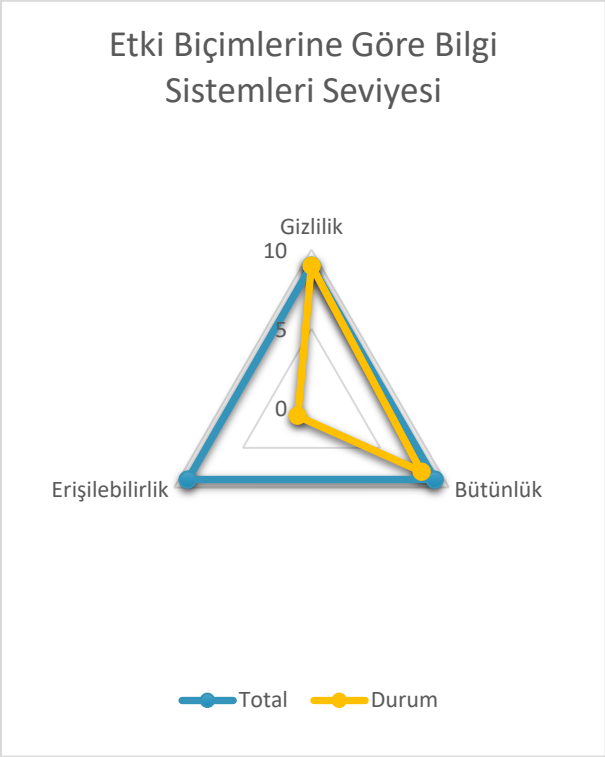
**GİZLİ**

*Bulgu Seviyeleri*

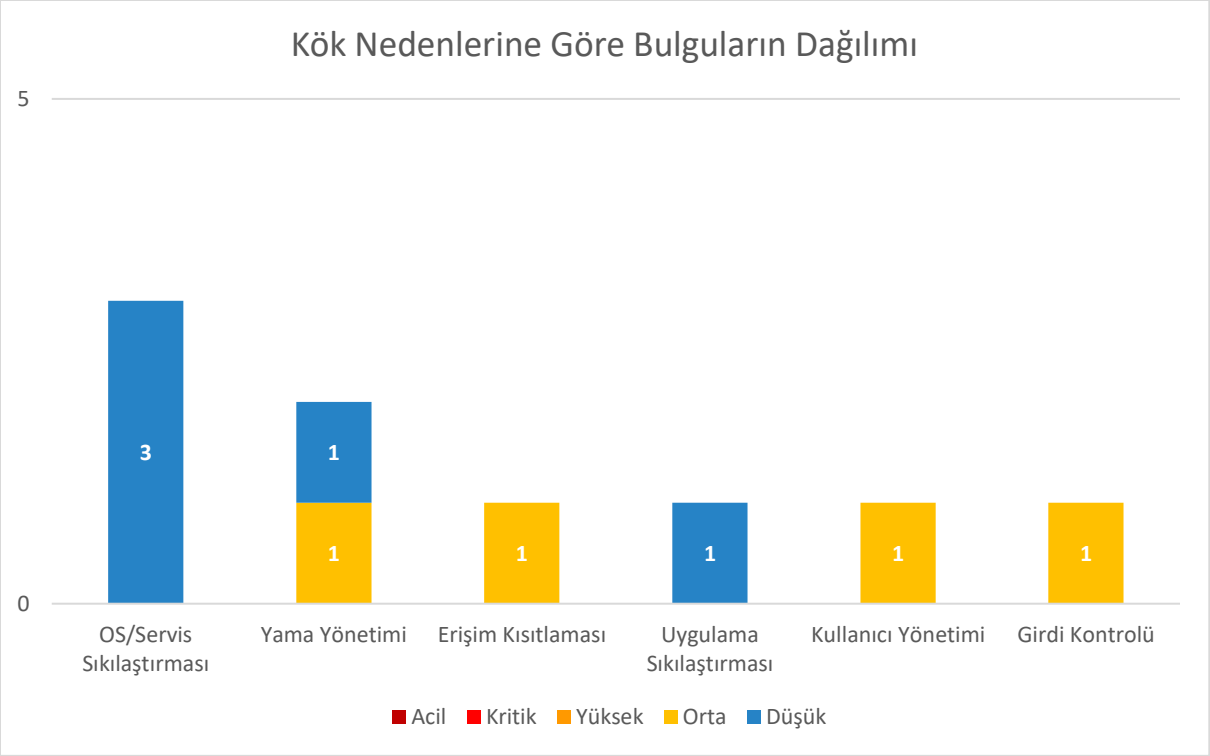
| Seviye | Açıklama |
|---|---|
| ACİL | Saldırganların tam yetki ile uzaktan komut çalıştırmaya, servis dışı bırakma saldırıları gerçekleştirmeye veya kritik verilerin sızdırılması ile sonuçlanabilecek zafiyetlerdir. |
| KRİTİK | Düşük yetki ile komut çalıştırma, servis aksatma ve siber saldırganların daha büyük saldırıları yapmasına olanak tanıyan zafiyetlerdir. |
| YÜKSEK | Hedef sistem üzerinde diğer zafiyetlerde kullanılabilecek bilgileri açığa çıkaran, tetiklenmesi durumunda kaynak kullanımını arttırabilecek zafiyetlerdir. |
| ORTA | Tek başına zafiyet olarak değerlendirilmeyen fakat diğer zafiyetler ile kullanıldığında önemli olabilecek zafiyetlerdir. |
| DÜŞÜK | Bilgi seviyesinde önerilerdir. Sektör ile ilgili en iyi yapılandırmalar göz önüne alınarak belirtilen sistem sıkılaştırmalarıdır. |

*Bulgu Grafikleri*



**GİZLİ**


Kök Nedenlerine Göre Bulguların Dağılımı
5
0
3
1
1
1
1
1
1
OS/Servis Sıkılaştırması
Yama Yönetimi
Erişim Kısıtlaması
Uygulama Sıkılaştırması
Kullanıcı Yönetimi
Girdi Kontrolü
Acil
Kritik
Yüksek
Orta
Düşük

*Kök Nedenler*

| Kök Neden | Açıklama |
|---|---|
| **Yama Yönetimi** | Hedef sistemde eksik olan güvenlik yaması veya kurumun yama yönetim süreçlerinden kaynaklanan bulgular |
| **Erişim Kısıtlaması** | Test edilen kullanıcı profili ile erişilmesinin sakıncalı olduğu ve atak vektörü olarak kullanabilecek kaynakların tespiti ile ilişkili bulgular |
| **Uygulama Sıkılaştırması** | Uygulamaların üzerinde gerçekleştirilebilecek sıkılaştırmaların olmamasından kaynaklanan bulgular |
| **OS/Servis Sıkılaştırması** | İşletim sistemi veya servislerin üzerinde gerçekleştirilebilecek sıkılaştırmaların olmamasından kaynaklanan bulgular |
| **Veritabanı Sıkılaştırması** | Veritabanı üzerinde gerçekleştirilebilecek sıkılaştırmaların olmamasından kaynaklanan bulgular |
| **Kullanıcı Yönetimi** | Uygulamalar/servisler üzerinde kullanıcı yönetiminden kaynaklanan, kullanıcı adı/parolaların veya kullanıcı oturumunu etkileyebilecek bulgular |
| **DNS Yapılandırması** | DNS kayıtlarından veya DNS sunucu/servis mimarisi eksikliklerinden kaynaklanan bulgular |
| **E-Posta Yapılandırması** | E-Posta sunucu/servis mimarisi ve yapılandırma eksikliklerinden kaynaklanan bulgular |
| **Ağ ve Sistem Mimarisi** | İletişim altyapısı ve aktif cihazlar ile sistem mimarisi yapılandırma eksikliklerinden kaynaklanan bulgular |
| **Girdi Kontrolü** | Uygulamanın girdi aldığı alanlarda gerekli kontrollerin ve kısıtlamaların uygulanmamasından kaynaklanan bulgular |

**GİZLİ**

## Test Kapsamı

| | | |
|---|---|---|
| **Testi Gerçekleştiren Firma**<br>RSU Bilişim ve Danışmanlık Hizmetleri A.Ş. | | **Test Kapsamı Veri Sahibi Firma**<br>Romsis Yazılım ve Bilgi Teknolojileri Ltd. Şti. |
| **Testi Gerçekleştiren Personel**<br>Furkan Ali Soysal | | **Sorumlu Personel**<br>Selim TURAL |
| **Raporu Hazırlayan**<br>Furkan Ali Soysal | **Raporu Kontrol Eden**<br>Kaan İlter | **Raporu Yayınlayan**<br>Yıldız Balatürk Erkan |
| **Test Başlangıç Tarihi**<br>22.08.2024 | | **Raporlama Tarihi**<br>29.08.2024 |
| **Test Kapsamı**<br>Web Uygulama Sızma Testi<br>- bob.romsis.com.tr:443 | | **Test Profili**<br>Erişim: İnternet<br>Profil: Anonim, Standart Kullanıcı |
| **Testte Kullanılan Kaynaklar**<br>İnternet:<br>- 185.124.86.25/29 | | **Test Hesapları**<br>Test Kullanıcıları:<br>- Sckn |

## Uyarı

Rapor içeriği gizli olup iki tarafın yazılı mutabakatı olmadan üçüncü taraflara basılı olarak ya da elektronik ortamda transfer edilemez veya paylaşılamaz.

Rapor, tarama süresi içinde varlığı bilinen veya tarafımızdan tespit edilen güvenlik açıklıklarını içerecektir. Tarama işlemi bittikten sonra rapor teslim edilene kadar geçen süre içerisinde çıkabilecek yeni güvenlik açıklarına dair eksikliklerden dolayı RSU sorumlu tutulamaz.

Rapor içinde yer alan çözüm önerilerine konu hakkında fikir verme amaçlı yer verilmiştir. Çözüm önerilerinin uygulanması sebebi ile çıkabilecek problemlerden RSU sorumlu tutulamaz. Önerilerde sunulan değişikliklerden gerçekleştirilmeden önce konu hakkında uzman kişilerden destek alınması tavsiye edilir.

## Sızma Testi Metodolojisi

Gerçekleştirilen sızma testi, OWASP (Açık Web Uygulaması Güvenlik Projesi) ve NIST (Ulusal Standartlar ve Teknoloji Enstitüsü) tarafından sağlanan yönergelerle uyumlu metodoloji çerçevesinde yürütülmüştür.

1. **Hazırlık Aşaması:**
    a. Sızma testinin kapsamının ve hedeflerinin belirlemesi.
    b. İlgili paydaşlardan yazılı yetkilerin alınması.
    c. Hedef sistemler ve uygulamalar hakkında ilgili bilgilerin toplanması.
    d. Uygulanabilir yasal veya düzenleyici gerekliliklerin belirlenmesi.
2. **İstihbarat Toplama:**
    a. Hedefle ilgili erişilebilir bilgilerin elde edilmesi.
    b. Ağ altyapısı, uygulamalar ve hizmetler hakkında bilgi toplanması için araçlar ve teknikler kullanılması.
    c. Potansiyel zafiyetlerin, güvenlik açıklarının ve saldırı vektörlerinin belirlenmesi.
3. **Tehdit Modelleme:**
    a. Hedef sistemlerin mimari yönlerinin analiz edilmesi ve potansiyel tehditlerin belirlenmesi.
    b. Potansiyel etkilerine ve olasılıklarına göre önceliklendirilen tehditlerin belirlenmesi.
    c. Saldırganlar için saldırı yüzeyinin ve potansiyel giriş noktalarının belirlenmesi.
4. **Zafiyet Analizi:**
    a. Otomatik araçlar ve manuel teknikler kullanılarak kapsamlı bir zafiyet değerlendirmesi yapılması.
    b. Hedef sistemlerde ve uygulamalarda tespit edilen zafiyetlerin belirlenmesi ve doğrulanması.
    c. Seviyeleri, potansiyel etkileri ve düzeltme adımlarını içeren kanıtların oluşturulması.
5. **İstismar:**
    a. Tespit edilen zafiyetlerin istismar edilerek yetkisiz erişim elde edilmesi veya hedef sistemler ile etkileşim girişiminde bulunulması.
    b. Etik hackleme teknikleri kullanılarak tespit edilen zafiyetlerin varlığının ve etkisinin doğrulanması.
    c. Başarılı istismar girişimlerinin adımlarının ve sonuçlarının belgelenmesi.
6. **İstismar Sonrası:**
    a. Elde edilen sistemlerde daha fazla bilgi toplama ve erişimi genişletmek için derinlemesine bir araştırma yapılması.
    b. Yetkileri yükseltme, süreklilik sağlama veya diğer sistemlere geçiş yapma fırsatların aranması.
    c. İstismar sonrası aşamasında gerçekleştirilen faaliyetlerin ve hedef ortamındaki potansiyel risklerin belgelemesi.
7. **Raporlama:**
    a. Belirlenen zafiyetleri, etkilerini ve düzeltme önerilerini içeren kapsamlı bir rapor derlenmesi.
    b. Potansiyel etkilerine göre belirlenen bulguların seviyelendirilmesi.
    c. Yönetici özeti, detaylı teknik bilgiler ve genel güvenlik durumunu iyileştirmek için öneriler sağlanması.
8. **Düzeltme ve Doğrulama:**

a. Belirlenen zafiyetleri ele almak için paydaşlarla iş birliği yaparak bir eylem planı oluşturulması.
b. Önerilen düzeltme adımlarının doğru bir şekilde uygulandığının doğrulanması.
c. Düzeltme çabalarının etkinliğini doğrulamak için yeniden test veya takip değerlendirmesin yapılması.

## Web Uygulama Sızma Testi Kontrol Listesi

1. Giriş Doğrulama: SQL enjeksiyonu ve cross-site scripting (XSS) gibi yaygın web uygulaması güvenlik açıklarını önlemek için giriş doğrulama tekniklerinin etkinliğinin test edilmesi.
2. Kimlik Doğrulama ve Oturum Yönetimi: Kimlik doğrulama mekanizmalarının, oturum yönetimi ve parola sıfırlama işlevselliğinin güvenliği.
3. Yetkilendirme ve Erişim Kontrolleri: Rol tabanlı erişim kontrolü (RBAC) ve kullanıcı yetkilendirme mekanizmalarının uygulanmasının değerlendirilmesi.
4. Hata İşleme ve İz Kaydı: Güvenlik olayları ve istisnalar için hata işleme mekanizmalarının ve iz kaydı uygulamalarının gözden geçirilmesi.
5. Güvenli Kodlama Uygulamaları: Giriş/çıkış doğrulama ve doğru hata işleme gibi güvenli kodlama uygulamalarına ve yönergelerine uyumun değerlendirilmesi.
6. API Güvenliği: Kimlik doğrulama, erişim kontrolleri ve giriş doğrulama gibi API'lerin güvenliği konusunda değerlendirme.
7. Dosya ve Kaynak Koruma: Hassas dosyaların ve kaynakların yetkisiz erişimden korunmasının doğrulanması.
8. Yapılandırma Yönetimi: Yapılandırma dosyalarının güvenliği konusunda değerlendirme, hassas bilgilerin açığa çıkmamasının sağlanması.

## Kullanılan Araçlar

| | | | | | |
|---|---|---|---|---|---|
| - Nessus | - Burp Suite | - Zaproxy | - Sqlmap | - Masscan | - Ffuf |
| - Nmap | - Metasploit | - Wpscan | - Nikto | - SSLyze | - Websploit |
| - Wireshark | - Commix | - Gobuster | - Netscan | - DirBuster | - nuclei |

# WEB UYGULAMA SIZMA TESTİ BULGULARI

## 1. Acil Seviye Web Uygulama Sızma Testi Bulguları

Acil seviye bulgu tespit edilmemiştir.

## 2. Kritik Seviye Web Uygulama Sızma Testi Bulguları

Kritik seviye bulgu tespit edilmemiştir.

## 3. Yüksek Seviye Web Uygulama Sızma Testi Bulguları

Yüksek seviye bulgu tespit edilmemiştir.

## 4. Orta Seviye Web Uygulama Sızma Testi Bulguları

| 4.1. Siteler Arası Betik Çalıştırma (Stored XSS) | | RS.290824.RA.401 |
|---|---|---|
| **Seviye:** Orta | | |
| **Etkilenen Sistem:** bob.romsis.com.tr:80 | **Erişim/Profil:** | İnternet/Standart |
| | **Etki Biçimi:** | Gizliliğin Bozulması<br>Bütünlüğün Bozulması |
| | **Kök Neden:** | Girdi Kontrolü |

**Açıklama:**

Siteler arası betik çalıştırma açıkları, web uygulaması üzerinden kullanıcılara yönelik saldırılar düzenlenebilmesine imkân veren güvenlik açıklarıdır. Bu tip açıklar, bir web uygulamasının, verilen HTTP cevabında kullanıcı tarafından sağlanmış bir girdiyi kontrol etmeden kullanmasıyla oluşur.

Yapılan incelemelerde "bob.romsis.com.tr" URL adresinde Operasyonlar altında bulunan Kuyruk No ve Havadakiler alanındaki Uçuş Numarası bölümünde, Tedarikçi Yönetimi altında bulunan İadesi Gelmeyen Uçuşlar bölümünde ve kasa işlemleri altında bulunan Kabin Borç/Alacak Takibi - Ödeme Ekranının açıklama bölümünde Depolanan XSS zafiyetinin olduğu tespit edilmiştir.

**Çözüm Önerisi:**

- Siteler arası betik çalıştırma saldırıları genellikle hedef olan kişinin web tarayıcısındaki güvenlik açıkları ve çalıştırılan betiğin içeriği ile sağlanır. Bu nedenle uygulamalara sağlanan girdi parametreleri kontrol edilmeden kullanılmamalıdır.
- Genel bir kural olarak, kullanıcı tarafından sağlanan girdiler incelenmeli, girdinin geçerliliği bir kural karşısında kontrol edilmeli ve uygun olmayan parametreler filtrelenmelidir.
- Tercihen engelleme türü olarak "Beyaz Liste" yaklaşımı kullanılmalı ve izin verilen karakterlerin dışındaki tüm karakterler engellenmelidir.

**Kaynak:**

Cross Site Scripting (XSS)
https://owasp.org/www-community/attacks/xss/
Category: Input Validation Vulnerability
http://www.owasp.org/index.php/Category:Input_Validation_Vulnerability
The Cross-site Scripting (XSS) Vulnerability: Definition and Prevention
https://www.netsparker.com/blog/web-security/cross-site-scripting-xss/
Cross-site scripting
https://portswigger.net/web-security/cross-site-scripting
Cross-site Scripting (XSS)
https://www.acunetix.com/websitesecurity/cross-site-scripting/

**GİZLİ**

## Ekran Görüntüsü:

**Request**

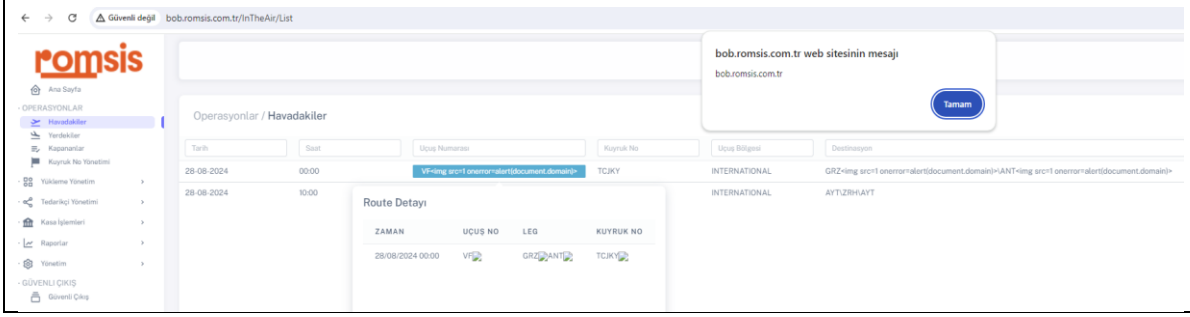
Pretty Raw Hex

```
POST /InTheAir/SaveOrder HTTP/1.1
Host: bob.romsis.com.tr
Content-Length: 4908
Accept-Language: tr-TR
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.6478.127 Safari/537.36
Content-type: application/json; charset=UTF-8
Accept: */*
Origin: http://bob.romsis.com.tr
Referer: http://bob.romsis.com.tr/InTheAir/Create
Accept-Encoding: gzip, deflate, br
Cookie: .AspNetCore.Antiforgery.y7wCGYr5vVk=
CfDJ8Cgh2ivlpldEuu5sJZwkZIvZs0_9i6vhz7mEXVC3e-SguVs-qXPdrEnsudVil188vcM13FupnlnJkwX4fXqIwf5VvMR3i_w3ITohllANx13cHNpUY8CYxjXvH9whqN_LDvVlQUdP5bxs8HJEAémX6s4
; romsis_auth_cookie=
CfDJ8Cgh2ivlpldEuu5sJZwkZIs60-HEYkfl5mtXJ2kQ9VBIhprH7CShn2jOCGcqeFs3OnYns3A2VgO49iwiyXnDl6t3BS6hWEbftta5Wqt3cR_oSjv_VdKsoSdjS6bCBvHyBEs_6Wp5oMTZuTdGLbShwBx
GMhLu_FxpWWUR0CiRSKQvn59aG1WXkGgJ-a4qNXFgcGAq3HNDXrV2VqThL5gBES6sBgWqhOcVWiSHI4Ria79nG5jdxd6E00AmeUn5r8Z_OSdPxMW5kvjXwFYXcyQn32iKWiFmXMeZONQ_tX-EJ_iAqJRJZpL
pLvDE4KAKJfm0pZ1QuFZxYuxERBfwIRFU1_nvhxKoAlBv7R90daWQxiBTR_ZgJYEMoSU48aZWjEeeL5JsxcL1lAE8xKcjCnEVCuKcxCxl283F0ZJtpmZWHHWlCnjqVeWD4qwR4Kp8sjotHQ5Sa2TUqHK4y
bYfc5Uhxs0eNSzc1eVQFSYDEBs7bO4EqUQTe9S8QeLGVbEiwR0Q_HijInuBEvx_XirY8gIyGvd-dEDY32VTw4PYosCytSj6jfuXsPRVpyqqsMxrsU_ZR10JF8qeSS7ataCznixXve7sNJstgPxJIéaq6A
m2xsQzr_hIyTOCZPWg_fBLcdjw; .AspNetCore.Mvc.CookieTempDataProvider=
CfDJ8Cgh2ivlpldEuu5sJZwkZIvZLqXWB_C3hzImgyXSNInBIEhotLRWn6UnGvgaUdg4-ZclTvePzS4Wldy57pBr4SueTJO9DlH9iezxiZ7s70HkxyzXBPouiScD3ohUU8gIABX8wuPxjAzXv-gFvsegQCl
R87ZJ9pGptquPZQH3trw9UIT-flKJJ39XBhx7whqIJutOwKgsuMUQylm5JA5XFoRINh7XJwUB16C6aK8E4l2Qh2W86k0qShIAoX4mCNtN5mt6OrPZRqyzUfWDxPHWKeozlPHZDiBj_An6vJwa5DGpFPWP5L
zIAQtgXFnO2IIJiBYhnyvMc0KWQgqLyEV8ELHnvE13Nev8jPwZ6pjnV1LQ6WRSx4ZdiSjv5czNvYldzK-ZCIi2y2aMLk6VhoZ6Y8UG6JYl-M45DmVG2Vyogmq4yiXmU_HSq8HJymynNBFMYEWEcWlzqYw6y
x54DsD-QBoayHttrxlnalHZBum3ZNwYIpoPvZily0_0ycD757708Wr5-ZMH2oOD-19lKmZnpxSIhSgUOHpe03ig4QIqH_knnDryPB2SKHVb3fNhkeRhJ5eIeQ08v3WjielxH3U7nx5yMoN3aLVajmPs_gFq
RzXwkcFZ5caAYat8FZ5lqBHiTcxRv04BZfUuwyyH-HDGAdQGq5j5WLKlGHnShxD2s2_V-2grv77bkrA5iLPOWRKFnw
Connection: keep-alive

{
  "tarih":"2024-08-28",
  "saat":"00:00:00",
  "priceId":"548a1c28-4f57-4c83-8104-08dcbb859e3d",
  "ucak":"312",
  "ucaksub":"",
  "kasa":"98a6d191-a0b2-42dc-6757-08dcc0d586e5",
  "kuyrukNo":"TCJKY",
  "teamCabinPrim":"10",
  "jackpotType":"0",
  "ucusType":"1",
  "charter":"t",
  "_FlightRoot":[
    {
      "RootNo":"VF<img src=1 onerror=alert(document.domain)>",
      "Code1":"GRZ<img src=1 onerror=alert(document.domain)>",
      "Code2":"ANT<img src=1 onerror=alert(document.domain)>",
      "Zaman":"28.08.2024 00:00:00",
      "KuyrukNo":"TCJKY<img src=1 onerror=alert(document.domain)>",
      "NetlineId":"0",
      "BacakDurumu":""
    }
  ],
```

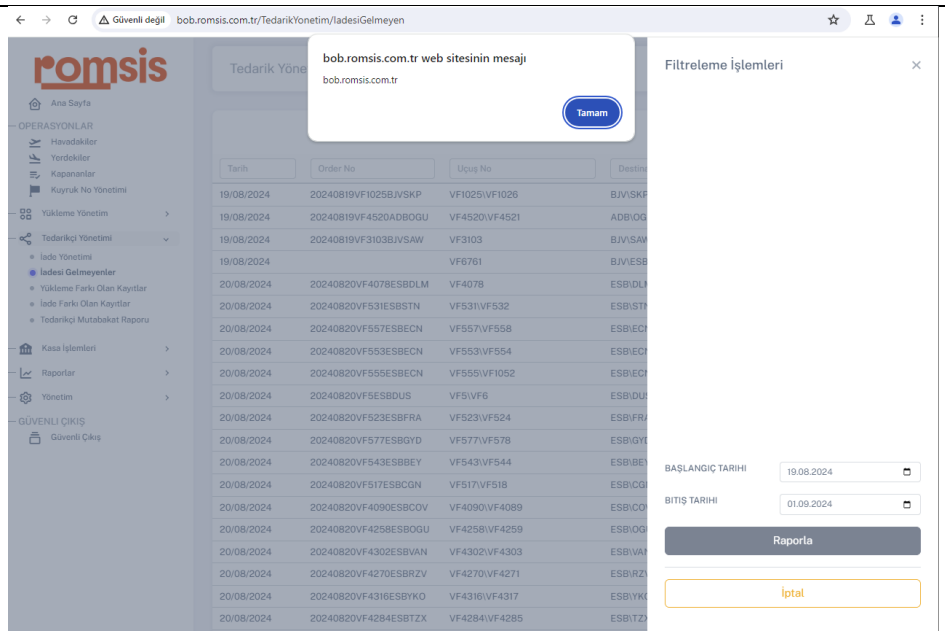
**Response**

Pretty Raw Hex Render

```
HTTP/1.1 200 OK
Content-Type: application/json; charset=utf-8
Vary: Accept-Encoding
Server: Microsoft-IIS/10.0
X-Powered-By: ASP.NET
X-Powered-By-Plesk: PleskWin
Date: Wed, 28 Aug 2024 16:06:00 GMT
Content-Length: 75

{
  "data":"a06b929b-90c5-44e0-cc0a-08dcc77b1fc2",
  "error":"",
  "isSuccess":true
}
```



**GİZLİ**




**Request**

Pretty Raw Hex

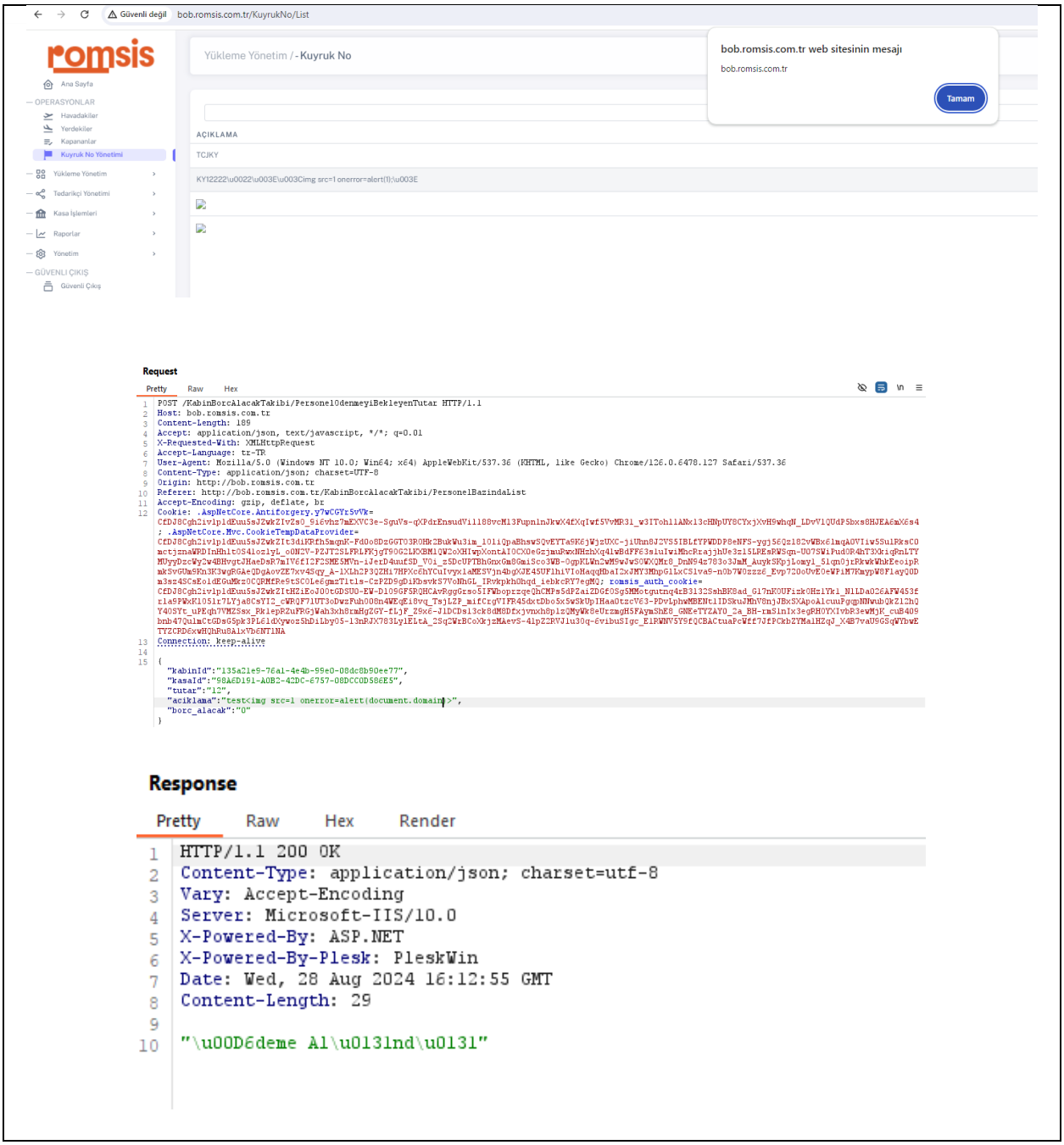
```
1  POST /KuyrukNo/Create?value=%3Cimg%20src=%221%22%20onerror=%22alert(document.domain)%22%3E HTTP/1.1
2  Host: bob.romsis.com.tr
3  Content-Length: 0
4  Accept: application/json, text/javascript, */*; q=0.01
5  X-Requested-With: XMLHttpRequest
6  Accept-Language: tr-TR
7  User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.6478.127
   Safari/537.36
8  Content-Type: application/json; charset=utf-8
9  Origin: http://bob.romsis.com.tr
10 Referer: http://bob.romsis.com.tr/KuyrukNo/List
11 Accept-Encoding: gzip, deflate, br
12 Cookie: .AspNetCore.Antiforgery.y7wCGYr5vVk=
   CfDJ8H18D4Pg1Q1JsZgWMyxnoYM1QplUEON6JYEycC65YEzvnoCFk_zVVcgHHMQM9ZRzdAd0sqzJvsk4icCMTEJ1J97nCQ4ZKACSxjLDIGTcChRysuQ6GHI7rqGzoD
   _fbbn6nzRJ4VglMLoHw-8qHxMjwVI; romsis_auth_cookie=
   CfDJ8H18D4Pg1Q1JsZgWMyxnoYNey8zulg7MOB1L-p2LX44qFWJ0j_RXFgQcfG2SDbKGZ-VSVZwKbaDtGliKP0dLrwIVPtEe-yCnIl0FzncdOEum_rxEzT7w9fWKdH
   IvIOXkewAVMk2-MWWFmHR8kpvbF-R1SCEX15mIouJahi_IaNmIMPasBoZJeYPZ_eBnDHYWKbCHe9wPqYyv8YEeAcbZbF3ASpi7BzB_X9jq9urJjKaSf1lLrK65sfVe
   heIlNnE_cC7dfftFSVVpkAeT-aJjVHYc-Qc6CyLgHIfV6yKMkdRctv8GHS3-KoDkkXgPR00Bjq1lKhjba76F43rXxECAh38VbfpBv0EZ6OWvy-pB0vwEHU_VCGUqCJ
   AUwZCR_mxv0BlYwD472S0bGJjimXCW3AEt6o_aXe63KDffeVtX_Ie5whYGhIUV291SFjglV_haq654Qd6FJC1EmwzpjJE05Fof5GJ9TWC714V94L0ITdwv0Mcft-kc
   wHxb9GFU4XZglKtMcewx_9yIIVL6zXrQQ38pGtNG27BS_PTwyfm-IuRd0_3GjP4AT01Nh_nE4cAWF04dKUCGw60oMedB28xA2_Otz007geHFRQXUfghSfUVvqef-81
   sSQDtWTiscPNBfww; .AspNetCore.Mvc.CookieTempDataProvider=
   CfDJ8H18D4Pg1Q1JsZgWMyxnoYMHct0Vfa88ZUSywUDeK_5VGcIem-7mk2zSHdt76H6HKq-YUTiWba0PB1R2oR-vFERMswIuW_miPJRaTK7DF5G54XALjHN4dm336x
   90mcUpxAk00-jjRciJGYyhM0GohqiTwm0sw8ow_Ivw3iQUlQ-rBM7puPDp7x5nF6CeMDSVoY76-sP5B_Y5PGHAJSBCHDhrk8Tp_4EHposhPa5uxG3I6YkKeFoIJBij
   Eb_Ehb69GCXsYSaSq8myUWTFT2OCUnlm47T6pnHQi7RUI8IKq3C15jrTjeRnmW94fwGoQPzl005bGZoDocHVw3TFmU_oRgW-BMTABYRSd6wAjKDSz30duXfVP2Queo
   ZHUcV__cOKELzDu_2tcudpvLQ4sgUYpzBxriFD7HlEoLIagBS-oOp3wAlGkItrYrMgW2qqINV38smEIyVU0Ohnc0yAliDiBV4XXOsGcu6oM8io6KwMqh3K54jcBxS5
   5QxG3Gx43cWR9i8edhN68Fumqt6t-3zGRmQy2dj3YsZAhUsR2BqTp7DuFniMc-YJ4d6wmGPxtXXyf8otYofLk-kepMNMgWDwk4L7Hrj7v3Sx-68GFvaW5S5vBQ51gT
   H57MiE5_qo9skmmS001Gns-Dajbe_mCdxQYAP573gVqAKniqg6Vq_ANogXkcdLT3u_DGtGch4U2wkhaV5Ts4qwzU2ma7llwUGVe7g
13 Connection: keep-alive
```

**Response**

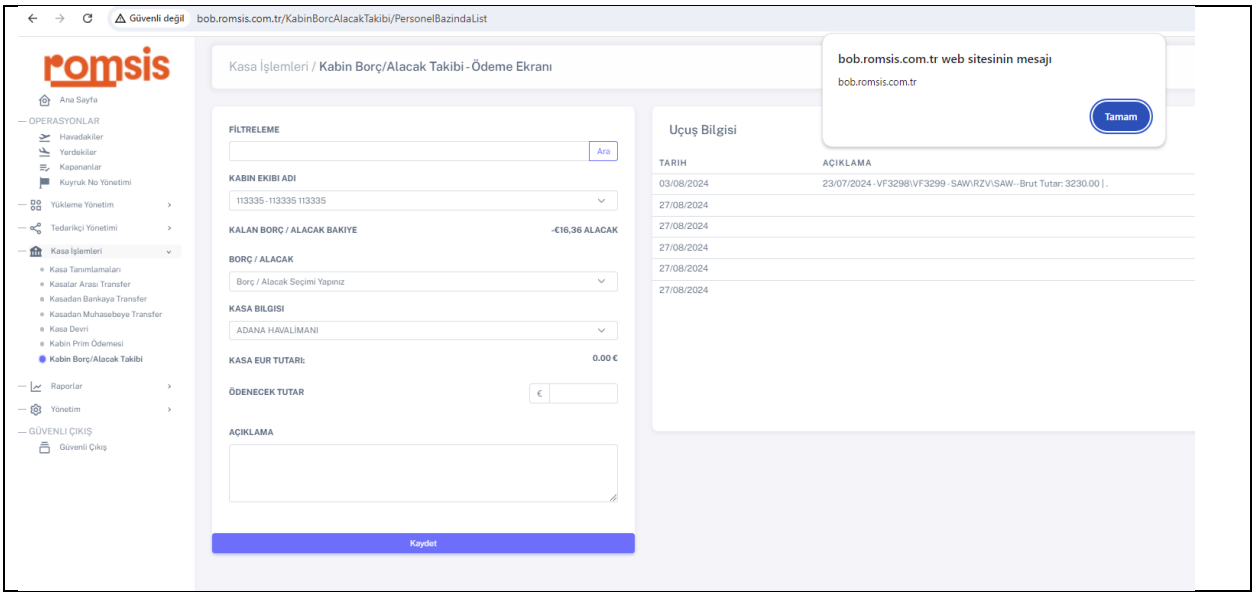
Pretty Raw Hex Render

```
1  HTTP/1.1 200 OK
2  Content-Type: application/json; charset=utf-8
3  Vary: Accept-Encoding
4  Server: Microsoft-IIS/10.0
5  X-Powered-By: ASP.NET
6  X-Powered-By-Plesk: PleskWin
7  Date: Wed, 28 Aug 2024 13:26:02 GMT
8  Content-Length: 9
9
10 "Success"
```

**GİZLİ**


Güvenli değil
bob.romsis.com.tr/KuyrukNo/List
romsis
Ana Sayfa
OPERASYONLAR
Havadakiler
Yerdekiler
Kapananlar
Kuyruk No Yönetimi
Yükleme Yönetim
Tedarikçi Yönetimi
Kasa İşlemleri
Raporlar
Yönetim
GÜVENLİ ÇIKIŞ
Güvenli Çıkış
Yükleme Yönetim / - Kuyruk No
bob.romsis.com.tr web sitesinin mesajı
bob.romsis.com.tr
Tamam
AÇIKLAMA
TCJKY
KY12222\u0022\u003E\u003Cimg src=1 onerror=alert(1);\u003E
Request
Pretty
Raw
Hex
POST /KabinBorcAlacakTakibi/PersonelOdenmeyiBekleyenTutar HTTP/1.1
Host: bob.romsis.com.tr
Content-Length: 189
Accept: application/json, text/javascript, */*; q=0.01
X-Requested-With: XMLHttpRequest
Accept-Language: tr-TR
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/126.0.6478.127 Safari/537.36
Content-Type: application/json; charset=UTF-8
Origin: http://bob.romsis.com.tr
Referer: http://bob.romsis.com.tr/KabinBorcAlacakTakibi/PersonelBazindaList
Accept-Encoding: gzip, deflate, br
Cookie: .AspNetCore.Antiforgery.y7wCGYr5vVk=
; .AspNetCore.Mvc.CookieTempDataProvider=
Connection: keep-alive
{
"kabinId":"135a21e9-76a1-4e4b-99e0-08dc8b90ee77",
"kasaId":"98AED191-A0B2-42DC-6757-08DCC0D58EE5",
"tutar":"12",
"aciklama":"test<img src=1 onerror=alert(document.domain)>",
"borc_alacak":"0"
}
Response
Pretty
Raw
Hex
Render
HTTP/1.1 200 OK
Content-Type: application/json; charset=utf-8
Vary: Accept-Encoding
Server: Microsoft-IIS/10.0
X-Powered-By: ASP.NET
X-Powered-By-Plesk: PleskWin
Date: Wed, 28 Aug 2024 16:12:55 GMT
Content-Length: 29
"\u00D6deme Al\u0131nd\u0131"

**GİZLİ**


Güvenli değil
bob.romsis.com.tr/KabinBorcAlacakTakibi/PersonelBazindaList
romsis
Ana Sayfa
OPERASYONLAR
Havadakiler
Yerdekiler
Kapananlar
Kuyruk No Yönetimi
Yükleme Yönetim
Tedarikçi Yönetimi
Kasa İşlemleri
Kasa Tanımlamaları
Kasalar Arası Transfer
Kasadan Bankaya Transfer
Kasadan Muhasebeye Transfer
Kasa Devri
Kabin Prim Ödemesi
Kabin Borç/Alacak Takibi
Raporlar
Yönetim
GÜVENLI ÇIKIŞ
Güvenli Çıkış
Kasa İşlemleri / Kabin Borç/Alacak Takibi - Ödeme Ekranı
bob.romsis.com.tr web sitesinin mesajı
bob.romsis.com.tr
Tamam
FİLTRELEME
Ara
KABIN EKIBI ADI
113335 - 113335 113335
KALAN BORÇ / ALACAK BAKIYE
-€16,36 ALACAK
BORÇ / ALACAK
Borç / Alacak Seçimi Yapınız
KASA BILGISI
ADANA HAVALİMANI
KASA EUR TUTARI:
0.00 €
ÖDENECEK TUTAR
€
AÇIKLAMA
Kaydet
Uçuş Bilgisi
TARIH
AÇIKLAMA
03/08/2024
23/07/2024 - VF3298\VF3299 - SAW\RZV\SAW - Brut Tutar: 3230.00 | .
27/08/2024
27/08/2024
27/08/2024
27/08/2024
27/08/2024

| 4.2. Güncel Olmayan JavaScript Kütüphanesi Kullanımı | | RS.290824.RA.402 |
|---|---|---|
| **Seviye:** Orta | | |
| **Etkilenen Sistem:** bob.romsis.com.tr:80 | **Erişim/Profil:** | İnternet/Anonim |
| | **Etki Biçimi:** | Gizliliğin Bozulması<br>Bütünlüğün Bozulması |
| | **Kök Neden:** | Yama Yönetimi |

**Açıklama:**

Güvenlik zafiyeti oluşturan JavaScript kütüphaneleri kullanılarak uygulama içerisine zararlı kodlar enjekte edilebilmekte ve uygulama yaşam döngüsüne bağlı olarak kullanıcı oturumları çalınabilmektedir. Bu nedenle bilinen zafiyetleri barındıran ve güncel olmayan JavaScript kütüphanelerinin kullanımından kaçınılması gerekir.

Yapılan incelemelerde uygulama içerisinde kullanılan, aşağıda belirtilmiş JavaScript kütüphanelerinin güncel olmadığı ve bilinen zafiyetlere sahip oldukları gözlenmiştir.

jQuery3.2.1

- http://bob.romsis.com.tr/login/vendor/jquery/jquery-3.2.1.min.js
- CVE-2020-11022, CVE-2020-11023, CVE-2019-11358

bootstrap 4.0.0

- http://bob.romsis.com.tr/login/vendor/bootstrap/css/bootstrap.min.css
- CVE-2024-6485, CVE-2024-6484

select2 4.0.3

- http://bob.romsis.com.tr/login/vendor/select2/select2.min.js
- CVE-2016-10744

moment.js 2.13.0

- http://bob.romsis.com.tr/login/vendor/daterangepicker/moment.min.js
- CVE-2022-24785, CVE-2017-18214

**Çözüm Önerisi:**

Kullanılan JavaScript kütüphanelerinin güncel kararlı sürümlere yükseltilmesi tavsiye edilmektedir.

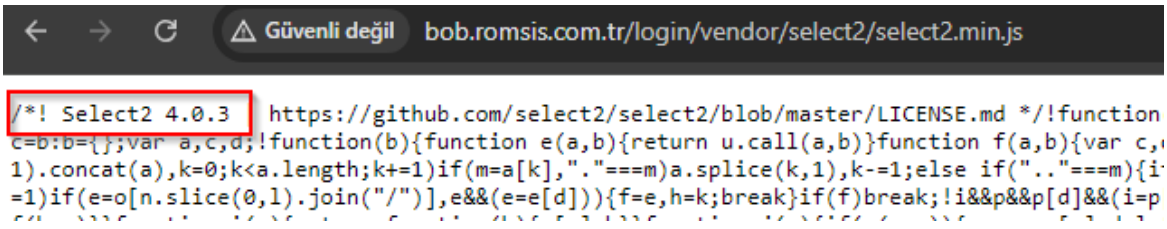
Bulguya tabii kütüphanelere ilişkin güncel sürümler aşağıdaki gibidir:
jQuery:3.7.1
bootstrap: 5.3
moment.js: 2.30.1
select2:4.1.0

**Kaynak:**

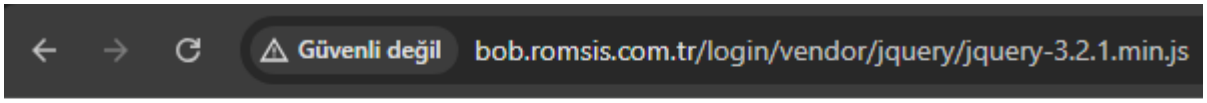
Over a Third of Websites Use Outdated and Vulnerable JavaScript Libraries
https://www.bleepingcomputer.com/news/security/over-a-third-of-websites-use-outdated-and-vulnerable-javascript-libraries/
https://nvd.nist.gov/vuln/detail/CVE-2020-11022
https://nvd.nist.gov/vuln/detail/CVE-2020-11023
https://nvd.nist.gov/vuln/detail/CVE-2019-11358
https://security.snyk.io/vuln/SNYK-JS-BOOTSTRAP-7444617

https://security.snyk.io/vuln/SNYK-JS-BOOTSTRAP-7444593
https://nvd.nist.gov/vuln/detail/CVE-2022-24785
https://nvd.nist.gov/vuln/detail/CVE-2017-18214
https://nvd.nist.gov/vuln/detail/CVE-2016-10744

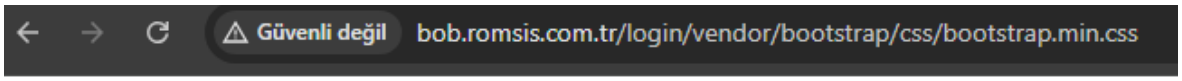
**Ekran Görüntüsü:**



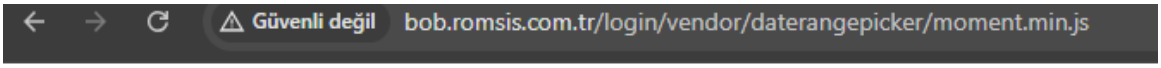

```
/*! Select2 4.0.3 | https://github.com/select2/select2/blob/master/LICENSE.md */!function
c=b:b={};var a,c,d;!function(b){function e(a,b){return u.call(a,b)}function f(a,b){var c,
1).concat(a),k=0;k<a.length;k+=1)if(m=a[k],"."===m)a.splice(k,1),k-=1;else if(".."===m){i
=1)if(e=o[n.slice(0,l).join("/")],e&&(e=e[d])){f=e,h=k;break}if(f)break;!i&&p&&p[d]&&(i=p
```




```
/*! jQuery v3.2.1 | (c) JS Foundation and other contributors | jquery.org/license *
!function(a,b){"use strict";"object"==typeof module&&"object"==typeof module.export
[],d=a.document,e=Object.getPrototypeOf,f=c.slice,g=c.concat,h=c.push,i=c.indexOf,j
[\s\uFEFF\xA0]+$/g,t=/^-ms-/,u=/-([a-z])/g,v=function(a,b){return b.toUpperCase()};
{return r.each(this,a)},map:function(a){return this.pushStack(r.map(this,function(b
```




```
/*!
 * Bootstrap v4.0.0-beta (https://getbootstrap.com)
 * Copyright 2011-2017 The Bootstrap Authors
 * Copyright 2011-2017 Twitter, Inc.
 * Licensed under MIT (https://github.com/twbs/bootstrap/blob/master/LICENSE)
```




```
//! moment.js
//! version : 2.13.0
//! authors : Tim Wood, Iskren Chernev, Moment.js contributors
//! license : MIT
//! momentjs.com
```

| 4.3. Parola Politikası Eksikliği | | | RS.290824.RA.403 |
|---|---|---|---|
| **Seviye:** | **Orta** | | |
| **Etkilenen Sistem:** | bob.romsis.com.tr:80 | **Erişim/Profil:** | İnternet/Standart |
| | | **Etki Biçimi:** | Gizliliğin Bozulması<br>Bütünlüğün Bozulması<br>Erişilebilirliğin Engellenmesi |
| | | **Kök Neden:** | Kullanıcı Yönetimi |

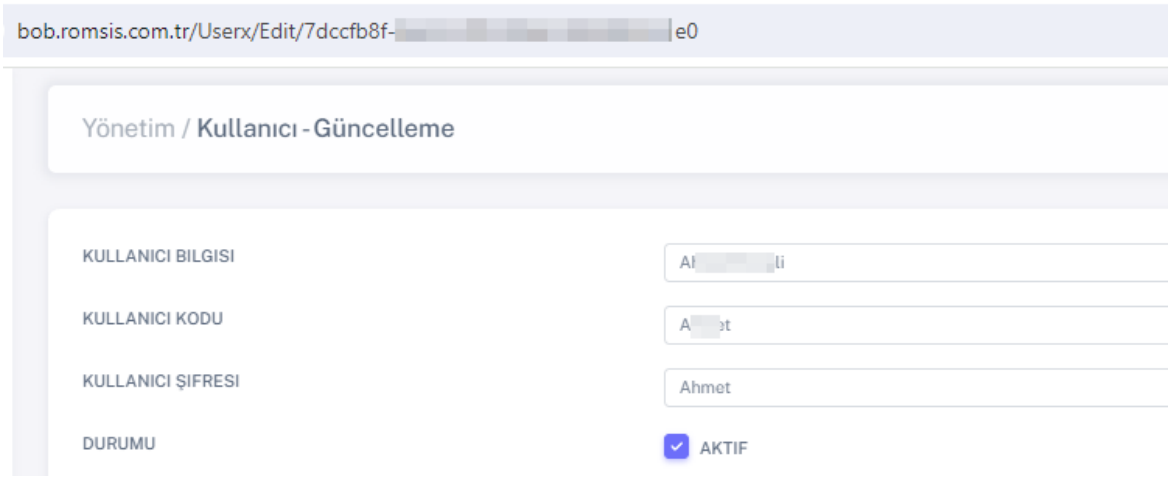
**Açıklama:**
Parola politikası eksikliği nedeniyle kullanılan basit parolalar brute-force(deneme yanılma) atakları ya da veri sızıntıları sonucunda kullanıcıların hızla ele geçirilmesine neden olmaktadır. Bu nedenle uygulama ve sistemlerin güçlü parola politikalarını destekleyecek şekilde geliştirilmesi önerilmektedir.

Yapılan incelemeler sonucunda kullanıcılara basit parola atandığı tespit edilmiştir.

**Çözüm Önerisi:**
-Yönetici hesap parolalarının en az 12 karakter uzunluğunda olması,
-Kullanıcı hesaplarının en az 8 karakter uzunluğunda olması,
-Parolanın içerisinde büyük, küçük harf, rakam ve özel karakter kullanmaya zorlanması,
-Parolaların belli aralıklarla değiştirmeye zorlanması(30/90 gün aralığında),
önerilmektedir.

**Kaynak:**
Best Practices for Enforcing Password Policies
https://technet.microsoft.com/en-us/library/ff741764.aspx
Password security best practices: Change passwords to passphrases
https://www.computerweekly.com/tip/Password-security-best-practices-Change-passwords-to-passphrases

**Ekran Görüntüsü:**



| 4.4. İnternetten Erişilebilir Hassas Servisler | | RS.290824.RA.404 |
|---|---|---|
| **Seviye:** Orta | | |
| **Etkilenen Sistem:** bob.romsis.com.tr:80 | **Erişim/Profil:** | İnternet/Anonim |
| | **Etki Biçimi:** | Gizliliğin Bozulması<br>Bütünlüğün Bozulması |
| | **Kök Neden:** | Erişim Kısıtlaması |

**Açıklama:**
Sunucular üzerinde kullanılan servislerin gerekli olmadıkça internet üzerinden kontrolsüz erişime açık olmaması gerekmektedir. FTP, SSH, MySQL gibi çeşitli servisler kimlik doğrulama metotları ile korunuyor olsa dahi ileride ortaya çıkabilecek bir açıklık ile yetkisiz erişime neden olabilir.

Yapılan incelemeler sonucunda internetten kontrolsüz erişime açık FTP servisleri tespit edilmiştir.

**Çözüm Önerisi:**
HTTP servisleri dışındaki servislerin internetten kontrolsüz erişime kapatılması tavsiye edilmektedir. Bu servislerin internet üzerinden erişim vermesi zorunlu ise IP kısıtlaması ya da VPN teknolojileri ile erişimin sınırlandırılması tavsiye edilmektedir.

**Kaynak:**
How to restrict MySQL port access
https://www.a2hosting.com/kb/developer-corner/mysql/restricting-mysql-port-access
how can i disable remote access of mysql?
https://www.digitalocean.com/community/questions/how-can-i-disable-remote-access-of-mysql
How to Restrict FTP Access by IP (via IIS)
https://support.managed.com/kb/a2208/how-to-restrict-ftp-access-by-ip-via-iis.aspx

**Ekran Görüntüsü:**

```
| nmap -sS -sV -p- bob.romsis.com.tr
Starting Nmap 7.94SVN ( https://nmap.org ) at 2024-08-28 17:43 +03
Nmap scan report for bob.romsis.com.tr (93.89.224.110)
Host is up (0.060s latency).
rDNS record for 93.89.224.110: 93-89-224-110.fbs.com.tr
Not shown: 65533 closed tcp ports (reset)
PORT   STATE SERVICE VERSION
21/tcp open  ftp     Microsoft ftpd
80/tcp open  http?
Service Info: OS: Windows; CPE: cpe:/o:microsoft:windows

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 169.82 seconds
```

```
└─# ftp 93.89.224.110
Connected to 93.89.224.110.
220 Microsoft FTP Service
Name (93.89.224.110:root):
```

## 5. Düşük Seviye Web Uygulama Sızma Testi Bulguları

| 5.1. HTTP Başlık Bilgisi Eksiklikleri | | | RS.290824.RA.501 |
|---|---|---|---|
| **Seviye:** | **Düşük** | | |
| **Etkilenen Sistem:** | bob.romsis.com.tr:80 | **Erişim/Profil:** | İnternet/Anonim |
| | | **Etki Biçimi:** | Gizliliğin Bozulması<br>Bütünlüğün Bozulması |
| | | **Kök Neden:** | OS/Servis Sıkılaştırması |

**Açıklama:**

HTTP başlık bilgisi eksiklikleri web uygulaması güvenliği açısından önemli bir rol oynamaktadır. Bu başlık bilgilerinin kullanılması XSS, Clickjacking ve HSTS gibi yapılandırma eksikliklerine karşı son kullanıcıları daha güvenli hale getirecektir.

Yapılan incelemeler sonucunda, etkilenen sistemlerde belirtilen web sunucuların güvenlik ile ilişkili HTTP başlıklarında eksikliklerin olduğu tespit edilmiştir.

- Strict-Transport-Security
- X-Content-Type-Options
- X-Frame-Options
- Content-Security-Policy

**Çözüm Önerisi:**

Aşağıda belirtilen başlık bilgilerinin tüm web sayfaları cevaplarında görüntülenecek şekilde yapılandırılması gerekmektedir. Başlık bilgilerinin kullanılması sonucunda clickjacking saldırı koruması, tarayıcı XSS koruması, içerik koruması, zorunlu SSL kullanımı ve önbellek kontrolü gibi yapılandırma ayarları aktif hale gelmiş olur.

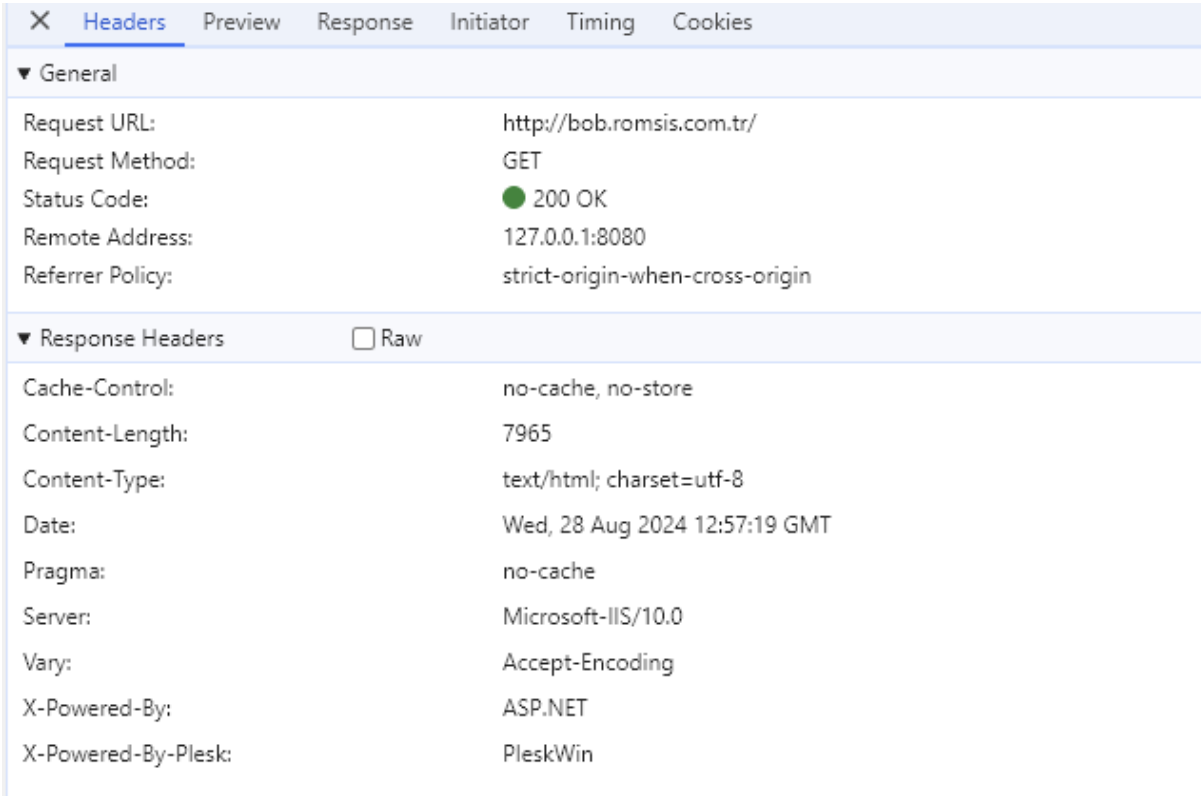
Strict-Transport-Security: max-age=16070400; includeSubDomains
X-Frame-Options: sameorigin
X-Content-Type-Options:nosniff
Cache-Control: no-cache, no-store, must-revalidate
Content-Security-Policy: KONTROL_ALANI değerler

**Kaynak:**

Clickjacking Defense Cheat Sheet
https://www.owasp.org/index.php/Clickjacking_Defense_Cheat_Sheet
List of useful HTTP headers
https://www.owasp.org/index.php/List_of_useful_HTTP_headers
HTTP Strict Transport Security
https://www.owasp.org/index.php/HTTP_Strict_Transport_Security
Best nginx configuration for improved security
https://gist.github.com/plentz/6737338
Referrer-Policy Not Implemented
https://www.netsparker.com/web-vulnerability-scanner/vulnerability-security-checks-index/referrer-policy-not-implemented/
CSP -Content Security Policy
https://www.netsparker.com.tr/blog/web-guvenligi/CSP-Content-Security-Policy/
Using the Same-Site Cookie Attribute to Prevent CSRF Attacks

https://www.netsparker.com/blog/web-security/same-site-cookie-attribute-prevent-cross-site-request-forgery/

**Ekran Görüntüsü:**



| 5.2. Hassas Bilgilerin Erişilebilir Olması | | | RS.290824.RA.502 |
|---|---|---|---|
| **Seviye:** | **Düşük** | | |
| **Etkilenen Sistem:** | bob.romsis.com.tr:80 | **Erişim/Profil:** | İnternet/Anonim |
| | | **Etki Biçimi:** | Gizliliğin Bozulması<br>Bütünlüğün Bozulması |
| | | **Kök Neden:** | Uygulama Sıkılaştırması |

**Açıklama:**

Bir uygulama ya da sunucu üzerinde kullanıcı, sunucu, uygulama hakkında hassas ya da hassas olabilecek verilerin internet üzerinden kontrolsüz erişime kapalı olması beklenir. Bu veriler kötü niyetli bir kullanıcı/saldırganın eline geçtiğinde sisteme zarar vermek, sistemi ele geçirmek ya da saldırı için yol haritası oluşturmak amacıyla kullanılabilir.

Yapılan incelemeler sonucunda "http://bob.romsis.com.tr/js/tools.js" URL adresinde iç ağ IP adresi bilgisinin bulunduğu tespit edilmiştir.

**Çözüm Önerisi:**

Hassas olabilecek her türlü verinin kontrolsüz bir şekilde erişimden kaldırılması tavsiye edilmektedir.

**Kaynak:**

A3:2017-Sensitive Data Exposure
https://owasp.org/www-project-top-ten/2017/A3_2017-Sensitive_Data_Exposure
Information disclosure vulnerabilities
https://portswigger.net/web-security/information-disclosure
Information Disclosure Issues and Attacks in Web Applications
https://www.netsparker.com/blog/web-security/information-disclosure-issues-attacks/

**Ekran Görüntüsü:**

| 5.3. Parolaların Veritabanında Açık Şekilde Saklanması | | RS.290824.RA.503 |
|---|---|---|
| **Seviye:** | **Düşük** | |
| **Etkilenen Sistem:** bob.romsis.com.tr:80 | **Erişim/Profil:** | İnternet/Standart |
| | **Etki Biçimi:** | Gizliliğin Bozulması<br>Bütünlüğün Bozulması |
| | **Kök Neden:** | Yama Yönetimi |

**Açıklama:**

Uygulamalar, çoğunlukla kullanıcı doğrulama işlemleri için kullanıcılara ait parola gibi hassas verileri veritabanında tutmaktadır. Veritabanında şifresiz şekilde saklanan hassas veriler, SQL Injection ya da farklı zafiyetler tarafından elde edildiğinde saldırganlar tarafından açık şekilde elde edilebilmekte ve kullanılabilmektedir.

İncelemeler sonucunda, http://bob.romsis.com web uygulaması üzerinden parolaların açık metin şeklinde tutulduğu tespit edilmiştir. Kullanıcılara ait parolaların açık metin olarak getirildiği için hassas verilerin veritabanında şifresiz şekilde saklandığı tespit edilmiştir.

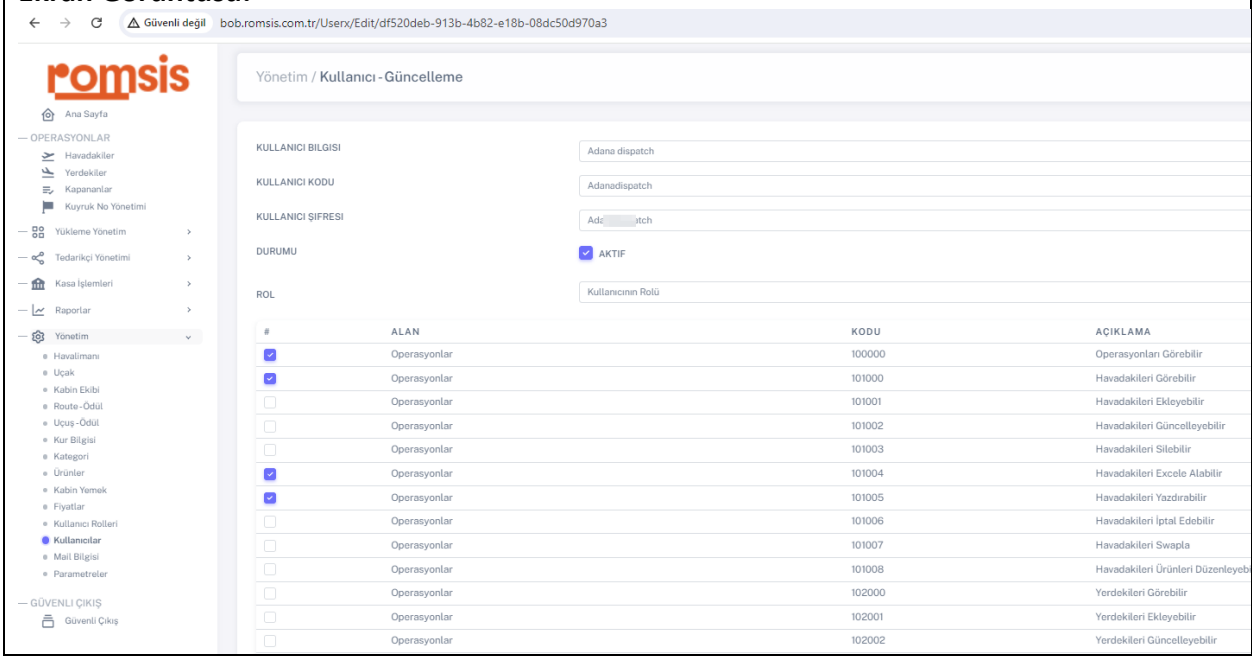
**Çözüm Önerisi:**

Hassas veriler veritabanında geri dönüştürülemeyecek şekilde şifreli (md5, sha256 vb.) şekilde saklanmalıdır.

**Kaynak:**

OWASP Password Plaintext Storage
https://owasp.org/www-community/vulnerabilities/Password_Plaintext_Storage
What is clear text passwords and why you shouldn't store them
https://medium.com/maclaurin-group/what-is-clear-text-passwords-and-why-you-shouldnt-store-them-e61c604b1fb7

**Ekran Görüntüsü:**



| 5.4. Tilde Kullanarak Dizin Listeleme Bilgisinin Açığa Çıkarılması | | | RS.290824.RA.504 |
|---|---|---|---|
| **Seviye:** | **Düşük** | | |
| **Etkilenen Sistem:** | bob.romsis.com.tr:80 | **Erişim/Profil:** | İnternet/Anonim |
| | | **Etki Biçimi:** | Gizliliğin Bozulması<br>Bütünlüğün Bozulması |
| | | **Kök Neden:** | OS/Servis Sıkılaştırması |

**Açıklama:**

IIS (Internet Information Services) üzerindeki dosya ve dizin isimlerinin Windows dosya sistemindeki 8.3 karakterlik kısa isim karşılıkları tilde (~) kullanılarak ele geçirilebilmektedir. Böylelikle web sunucusunda tutulan gizli dizin ya da belgelere ulaşılabilir. Örneğin 'firmalar.aspx' adındaki bir dosya zafiyet kullanılarak 'firmal~1.asp' olarak tespit edilebilecektir.

Yapılan incelemeler sonucunda etkilenen web sunucusunda tilde kullanılarak yerel klasör ve dosya isimlerinin tespit edilebildiği görülmüştür.

**Çözüm Önerisi:**

Web sunucusuna gelen istekler arasından tilde(~) karakteri bulunan isteklerin işlenmemesi, 400/403/404 gibi varsayılan hata sayfalarının özelleştirilmiş hata sayfaları ile değiştirilmesi ve dosya/dizin isimlerinin 8.3'ten uzun tercih edilmesi tavsiye edilir.

**Kaynak:**

Microsoft IIS tilde character "~" Vulnerability/Feature –Short File/Folder Name Disclosure
https://soroush.secproject.com/downloadable/microsoft_iis_tilde_character_vulnerability_feature.pdf
Fixing the IIS tilde vulnerability
https://serverfault.com/questions/670658/fixing-the-iis-tilde-vulnerability

**Ekran Görüntüsü:**

```
[+] Started scan for URL "http://bob.romsis.com.tr/"

[*] Trying method "OPTIONS" with magic final part "/~1/.rem"

[+] Host "http://bob.romsis.com.tr/" is vulnerable!
[+] Used HTTP method: OPTIONS
[+] Suffix (magic part): /~1/.rem

[*] Starting filename and directory bruteforce on "http://bob.romsis.com.tr/"
[i] File: DOCUME~1.DLL
[i] File: WEB~1.CON
[i] File: CLOSED~1.DLL
[i] File: DOTNET~1.DLL
[i] File: APPSET~2.JSO
[i] File: APPSET~1.JSO
[i] File: MIDCAC~1.DLL
[i] File: HAEC10~1.DLL
[i] File: HANGFI~1.DLL
[i] File: HANGFI~2.DLL
[i] File: HANGFI~3.DLL
[i] File: HANGFI~4.DLL
[i] File: MIAE1A~1.DLL
[i] File: MICROS~1.DLL
[i] File: AZUREI~1.DLL
[i] File: MICROS~2.DLL
```

| 5.5. Web Sunucu ve Uygulama Versiyon Bilgisinin Açığa Çıkarılması | | RS.290824.RA.505 |
|---|---|---|
| **Seviye:** | **Düşük** | |
| **Etkilenen Sistem:** bob.romsis.com.tr:80 | **Erişim/Profil:** | İnternet/Anonim |
| | **Etki Biçimi:** | Gizliliğin Bozulması |
| | **Kök Neden:** | OS/Servis Sıkılaştırması |

**Açıklama:**

Web sunucu ve uygulamalar varsayılan olarak HTTP başlıklarında ve uygulama içerisinde kullanılan teknoloji ve kütüphaneler ile sürüm bilgilerini gönderilen cevaplar içerisine eklemektedir. Saldırganlar hedef sistem hakkında bilgi toplamak ve altyapı analizi için bu tür bilgileri kullanarak neler yapılabileceğinin çıktısını üretirler.

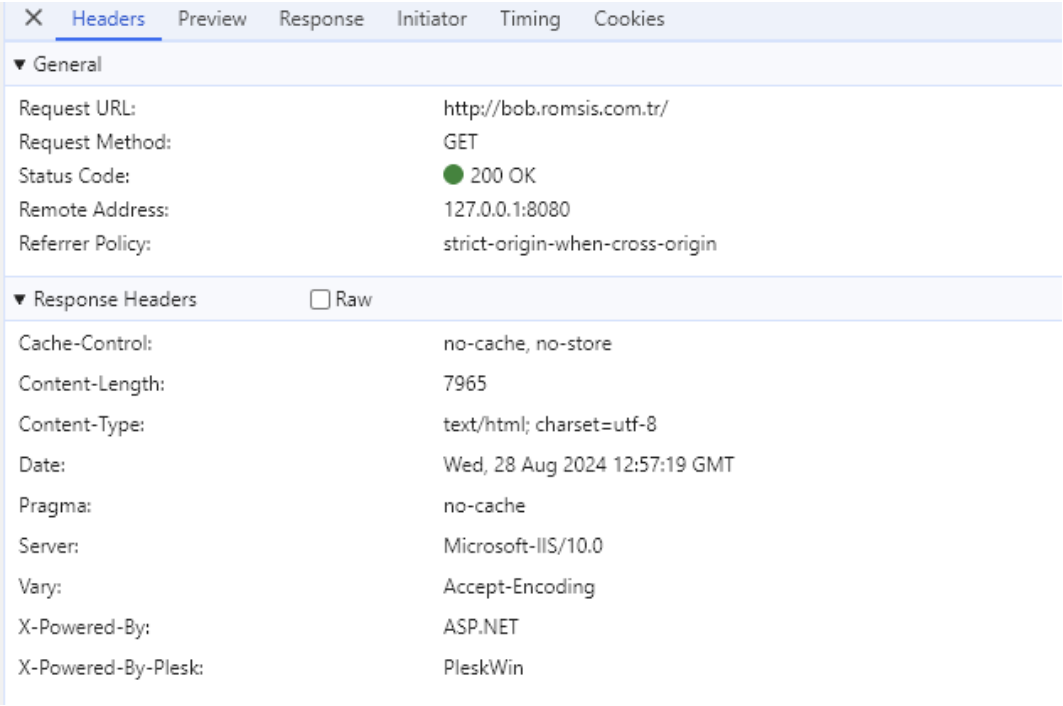
Yapılan incelemelerde, etkilenen sistemlerde belirtilen web sunucu ve üzerinde çalışan teknolojiler ile ilgili versiyon bilgisinin açığa çıkarıldığı tespit edilmiştir.

- Server: Microsoft-IIS/10.0
- X-Powered-By: ASP.NET
- X-Powered-By-Plesk: PleskWin

**Çözüm Önerisi:**

Web sunucu ve uygulamalar için X-Powered-By, Server gibi başlıklar başta olmak üzere, sistem hakkında bilgi verebilecek başlık ve çıktılar konfigürasyonlar üzerinden devre dışı bırakılmalıdır.

**Kaynak:**

Fingerprint Web Server
https://owasp.org/www-project-web-security-testing-guide/latest/4-Web_Application_Security_Testing/01-Information_Gathering/02-Fingerprint_Web_Server
Petefreitag - Apache security
http://www.petefreitag.com/item/505.cfm
MSDN - Error Handling in ASP.NET Pages and Applications
http://msdn.microsoft.com/en-us/library/w16865z6.aspx
Web Application Fingerprinting
https://capec.mitre.org/data/definitions/170.html

**Ekran Görüntüsü:**